

Security Incident Report

Cloudora Security Operations | Template CLD-IR-TEMPLATE | Complete every section. If a section is empty, write why.

Report ID	CLD-IR-0001
Related ticket	CLD-0001
Report title	Password Spray Campaign in Account Takeover of CEO Mailbox and HRBP SharePoint
Analyst	Uju Igweokwu
Date of report (UTC)	2026-08-04
Incident severity	P1 Two accounts confirmed compromised, one the CEO, with confirmed mailbox and document access; source campaign targeted 26 accounts in total.
Status	Open / Contained / Eradicated / Closed
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

Four to five sentences a non-technical executive can read in 60 seconds: what happened, how it was found, what the attacker did, what has been done about it, and what the business risk was. No IP addresses, no query syntax, no acronyms without expansion. Write this section LAST, after everything else is filled in.

Between 8th and the 10th of August 2026, an external attacker ran a password spray campaign against 26 Cloudora Microsoft 365 account from three IP addresses in Lagos, Nigeria. On the third night the attacker guessed valid credentials for two accounts, CEO Daniel Reeve and HR Business Partner Priya Nair and logged in successfully within minutes of each other. The attacker read the CEO's mailbox and, 35 minutes later, accessed documents in Priya Nair's ShearPoint Online, using access that Cloudora's own log data now shows was visible as a spray pattern, not yet as a breach two full days before either account was taken over. Cloudora SOC has since revoked sessions and reset credentials for both compromised accounts and is forcing password reset across the other 24 accounts the attacker tried but failed to break into. No evidence of persistence (new MFA methods or mailbox forwarding rule) has been found for either account in the log sources reviewed, but this reflects the limits of current logging rather than confirmed clean status so both accounts remain under enhanced monitoring.

2. Incident timeline

Every significant event in order, all times in UTC. Include attacker actions, victim actions, and response actions. Cite the log source for each row - a timeline entry you cannot evidence does not belong here.

Time (UTC)	Source	Event	Evidence / notes
Aug 08, 03:16:43	CloudoraSignIn_CL	Spray attempt fail against priya.niar from 102.89.44.23	Row 1, priya.nair sign-in query
Aug 08, ~03:09-03:26 (night !)	CloudoraSignIn_CL	Same spray IP set fails against daniel.reeve (CEO); night one activity visible in logs two days before breach	Detection-rule analysis, Task 3 answer key
Aug 08, 03:52:43	CloudoraSignIn_CL	Spray attempt fails against priya.nair from 102.89.44.17	Row 2, priya.nair sign-in query

Aug 09, 01:40:46-03:49:53	CloudoraSignIn_CL	Further spray failures against priya.nair (3 attempts) from 102.89.44.17/23	Rows 3–5, priya.nair sign-in query
Aug 10, ~03:09-03:10	CloudoraSignIn_CL	Final spray failures against daniel.reeve immediately preceding compromise	Task 4 evidence checklist
Aug 10, ~03:12	CloudoraSignIn_CL	daniel.reeve (CEO) account compromised, successful sign-in from Lagos, Nigeria (never-before-seen Windows 10 / Chrome 125 device)	Task 4 evidence checklist
Aug 10, 03:44:55	CloudoraSignIn_CL	Spray attempt fails against priya.nair from 102.89.45.101 (same IP that will succeed 3 minutes later)	Row 6, priya.nair sign-in query
Aug 10, 03:47:18	CloudoraSignIn_CL	priya.nair account compromised – successful Microsoft 365 sign-in from 102.89.45.101, Lagos, Nigeria	Row 7, priya.nair sign-in query
Aug 10, ~03:12-03:26	CloudoraSignIn_CL	Attacker accesses daniel.reeve mailbox during the compromised session	<i>Task 4 evidence checklist (pattern: single 03:12–03:26 burst)</i>
Aug 10, 03:52:40	CloudoraSignIn_CL	Attacker accesses SharePoint Online as priya.nair – 35 minutes after the CEO compromise, same session window	Row 8, priya.nair sign-in query
Aug 10, 08:41	CloudoraSignIn_CL	Genuine daniel.reeve sign-in from London same day – confirms account owner unaware of overnight compromise	Task 4 evidence checklist
Aug 05-10 (ongoing)	CloudoraSignIn_CL	omar.farah generates 12 successful daytime sign-ins from Dubai on his usual iOS device – reviewed and cleared as legitimate travel, not compromise	Task 4 answer key
Aug 06, 11:15 (query run)	CloudoraAudit_CL	Audit log query for priya.nair returns no rows – no MFA registration or inbox-rule changes visible from attacker IPs in this log source	priya.nair audit query, “No Rows To Show”

3. Findings

One numbered finding per distinct fact you established. State the finding in one sentence, then the evidence (which query, which rows), then why it matters. Findings are facts, not guesses - if you are inferring, say so.

Finding 1 CEO account compromised via password spray, mailbox accessed

daniel.reeve@cloudora.io was compromised on 10 August at approximately 03:12 UTC after repeated spray failures on 8–9 Aug, from an IP in the same Lagos /24 block used against every other spray target. The sign-in used a Windows 10 / Chrome 125 device never previously seen on the account, and the attacker accessed the mailbox during that session. The account owner's own legitimate London sign-in did not occur until 08:41 the same day, confirming he was not the source of the overnight activity. This is an inference from device, timing, and location; it is treated as a confirmed compromise on the strength of that combined evidence, consistent with Cloudora's standard for distinguishing takeover from travel.

Finding 2 Second account compromised: priya.nair, SharePoint documents accessed

priya.nair@cloudora.io was compromised at 03:47:18 UTC on 10 August from 102.89.45.101, three minutes after a final failed attempt from the same IP. The attacker accessed SharePoint Online at 03:52:40 – 35 minutes after the CEO compromise – indicating the attacker worked both accounts within a single session window rather than as two unrelated incidents.

Finding 3 Spray campaign targeted 26 accounts; only 2 were breached

Excluding the two breached accounts, 24 additional @cloudora.io accounts show failed sign-ins (ResultType 50126) from the same spray IPs between 8 and 10 August, with no successful sign-in from those IPs on any of them. These accounts were targeted but not breached and require precautionary password resets rather than full incident treatment; alba.vega, amelia.frost, aria.reid, cole.burke, dina.said, emma.hayes, ethan.wells, freya.lynn, gwen.muir, isla.grant, joel.kerr, jude.ross, kian.patel, leah.stone, lena.voss, liam.doyle, mira.shah, nina.cole, omar.farah, rhys.owen, ruth.dean, ryan.boyd, seth.lane, sofia.marino (all @cloudora.io)

Finding 4 No persistence evidence found for priya.nair in available logs

A CloudoraAudit_CL query scoped to priya.nair as target user returned zero rows – no MFA registration changes and no inbox-rule creation from attacker IPs are visible in this log source. This is treated as an absence of evidence, not evidence of absence: the account still receives the full containment sequence (session revocation, credential reset, MFA review, inbox-rule audit) rather than being cleared on the basis of a clean audit query alone.

Finding 5 omar.farah's Dubai sign-ins are a false positive, not a compromise

omar.farah@cloudora.io shows 12 successful sign-ins from Dubai across 8–10 August, all in daytime hours (09:00–19:00), all from his established iOS 17 / Mobile Safari device, with no failed attempts preceding any of them. This pattern is consistent with legitimate travel and inconsistent with the takeover pattern seen on daniel.reeve and priya.nair (night-time access, unfamiliar device, failures immediately before success). Note that omar.farah was separately targeted by the same spray campaign and, on that basis alone, still requires a precautionary password reset under Finding 3 – the false-positive finding and the near-miss finding are independent and both apply to this account.

4. Indicators of compromise (IOCs)

Everything another analyst would need to detect or block this attacker: IP addresses, device names, rule names, user agents. One row per indicator, with where you found it.

Type	Value	First seen (UTC)	Context
IP address	102.89.44.23	Aug 08, 03:16:43	Spray source, Lagos, Nigeria
IP address	102.89.44.17	Aug 08, 03:52:43	Spray source, Lagos, Nigeria
IP address	102.89.45.101	Aug 10, 03:44:55	Spray source; succeeded against priya.nair and, per Finding 1, associated with the daniel.reeve compromise window

Device / user agent	Windows 10 / Chrome 125	Aug 10, ~03:12	Never previously seen on daniel.reeve's account; used for CEO mailbox access
Compromised account	daniel.reeve@cloudora.io	Aug 10, ~03:12	CEO; mailbox accessed
Compromised account	priya.nair@cloudora.io	Aug 10, 03:47:18	HR Business Partner; SharePoint Online documents accessed

5. MITRE ATT&CK; mapping

Map each attacker behaviour you observed to a technique. Use the technique ID (e.g. T1110.003) and name, and point to the finding that evidences it. Only map what you actually saw in the logs.

Tactic	Technique ID	Technique name	Evidenced by
Credential Access	T1110.003	Brute Force: Password Spraying	Finding 3 – 26 accounts failed from the same 3 IPs over 3 nights
Initial Access	T1078	Valid Accounts	Findings 1 & 2 – successful sign-ins using guessed valid credentials
Collection	T1114.002	Email Collection: Remote Email Collection	Finding 1 – CEO mailbox accessed after sign-in
Collection	T1213	Data from Information Repositories	Finding 2 – SharePoint Online document access as priya.nair

6. Scope

Who and what was affected. List: (a) accounts confirmed compromised, (b) accounts targeted but not breached, (c) accounts investigated and cleared, with the evidence for each. If you have not checked scope, the incident is not scoped - say so explicitly.

Accounts confirmed compromised

mar.farah@cloudora.io shows 12 successful sign-ins from Dubai across 8–10 August, all in daytime hours (09:00–19:00), all from his established iOS 17 / Mobile Safari device, with no failed attempts preceding any of them. This pattern is consistent with legitimate travel and inconsistent with the takeover pattern seen on daniel.reeve and priya.nair (night-time access, unfamiliar device, failures immediately before success). Note that omar.farah was separately targeted by the same spray campaign and, on that basis alone, still requires a precautionary password reset under Finding 3 – the false-positive finding and the near-miss finding are independent and both apply to this account.

Accounts targeted but not breached

omar.farah@cloudora.io shows 12 successful sign-ins from Dubai across 8–10 August, all in daytime hours (09:00–19:00), all from his established iOS 17 / Mobile Safari device, with no failed attempts preceding any of them. This pattern is consistent with legitimate travel and inconsistent with the takeover pattern seen on daniel.reeve and priya.nair (night-time access, unfamiliar device, failures immediately before success). Note that omar.farah was separately targeted by the same spray campaign and, on that basis alone, still requires a precautionary password reset under Finding 3 – the false-positive finding and the near-miss finding are independent and both apply to this account.

Accounts investigated and cleared (false positives)

omar.farah@cloudora.io shows 12 successful sign-ins from Dubai across 8–10 August, all in daytime hours (09:00–19:00), all from his established iOS 17 / Mobile Safari device, with no failed attempts preceding any of them. This pattern is consistent with legitimate travel and inconsistent with the takeover pattern seen on daniel.reeve and priya.nair (night-time access, unfamiliar device, failures immediately before success). Note that omar.farah was separately targeted by the same spray campaign and, on that basis alone, still requires a precautionary password reset under Finding 3 – the false-positive finding and the near-miss finding are independent and both apply to this account.

7. Actions taken

What was actually done, by whom, at what time (UTC), in order. Containment first (stop the bleeding), then eradication (remove attacker access and persistence), then verification (prove it worked). An action without a timestamp did not happen.

Time (UTC)	Action	Performed by	Verified how
Aug 10 (post-detection)	Revoked active sessions for daniel.reeve and priya.nair	Cloudora SOC	Re-query of CloudoraSignIn_CL for new sign-ins post-revocation
Aug 10 (post-detection)	Reviewed MFA methods and inbox rules on both accounts	Cloudora SOC	CloudoraAudit_CL query – no attacker-initiated changes found (Finding 4)
Aug 10–06	Forced password reset for the 24 targeted-but-not-breached accounts	Cloudora SOC/ IT	To be confirmed via CloudoraAudit_CL once complete
Aug 10–06	Deploy scheduled detection rule (Section 8) to catch future spray activity within 6 hours	Cloudora SOC	validation against historical Aug 8 data

8. Recommendations

What the client should change so this attack fails next time. Be specific and prioritised: quick wins first, then strategic changes. Every recommendation should trace back to a finding.

- *Deploy the spray-detection analytics rule now (10+ distinct accounts failing from one source IP within a 6-hour window; see KQL below), scheduled to run every 6 hours – this would have alerted on night one, two days before the breach.*
- *Complete the forced password reset for the 24 targeted accounts as precautionary resets and confirm via CloudoraAudit_CL.*
- *Add a companion rule that fires when an IP already flagged by the spray rule later succeeds against any account – a breach alarm distinct from the attempt alarm.*

Strategic changes

- *Enforce MFA tenant-wide, with no exceptions for executive accounts – the CEO account had no additional protection despite being a higher-value target.*
- *Apply conditional access policies to restrict or step-up authentication for sign-ins from unfamiliar countries/ASNs, particularly outside business hours.*

- Lower the spray-detection threshold specifically for executive and finance accounts given their higher impact if breached.
- Extend audit logging coverage so that mailbox-rule and MFA-registration events are reliably captured for every account, the empty result for priya.nair should increase confidence only to the extent the log source is known to be complete.

Detection engineering: the rule that catches night one

```
// scheduled analytic rule to run every 1hr over the last 1hr of data
CloudoraSignIn_CL
| where TimeGenerated > ago(1h)
| where ResultType == "50126"
| summarize Failures = count(),
    TargetedAccounts = dcount(UserPrincipalName),
    SampleAccounts = make_set(UserPrincipalName,5),
    AppTargeted = dcount (AppDisplayName),
    Applications = make_set(AppDisplayName,5),
    UserAgent = make_set(UserAgent,3)
    by IPAddress, Country
|where TargetedAccounts >= 10
|where Failure >= 30
|extend Severity = case(
    TargetedAccount >= 50, "High",
    TargetedAccount >= 20, "Medium",
    "Low")
| order by Severity desc, TargetedAccounts desc
```

- * Reduced the detection window from 6 hours to 1 hour to improve detection speed.
- * Added a minimum failure count to reduce false positives.
- * Included applications and user agents to improve analyst triage.
- * Recommended excluding trusted IPs and service accounts to minimise alert fatigue.
- * Suggested correlating failed logins with subsequent successful authentications to prioritise genuine compromises.

9. Lessons learned

What worked in this investigation, what was slow or missing, and what the SOC should do differently. This section is about the response, not the attacker.

- What worked: the timeline / baseline / persistence method cleanly separated a real takeover (daniel.reeve, priya.nair) from a false positive (omar.farah) using the same evidence categories each time, time of day, device, prior failures, and owner's own activity.
- What was slow or missing: the spray was visible in CloudoraSignIn_CL on 8 August but no scheduled rule existed to surface it, detection only happened after the breach, via manual scoping.
- What to do differently: deploy the Section 8 detection rule and its breach-alarm companion before closing this incident, and treat an empty CloudoraAudit_CL result as inconclusive rather than reassuring until log coverage is confirmed complete.

Template notes: keep all times UTC; write findings as you work, not at the end; the executive summary is written last but appears first. Completed example for this scenario: report CLD-IR-0001.